

THREAT CARD

T-13

COMPROMISED SOFTWARE VENDOR UPDATE

STEP: INITIAL COMPROMISE
VECTOR: MALWARE

CLUE FOR THREAT ORCHESTRATOR
"Your monitoring systems detect unusual outbound connections from a recently deployed software update to an IP address not associated with the vendor. The update was digitally signed but verification shows the signature was backdated. Hundreds of organizations received the same malicious update."

WHY THIS WORKS
Supply chain compromises affect entire industries simultaneously. Organizations trust vendor updates and often deploy them automatically without deep inspection. The attacker gains access to thousands of targets at once. Real-world example: SolarWinds, 3CX. DETECTION DIFFICULTY: High The malware appears legitimate due to trusted vendor origin.

INCIDENT ZERO · INCIDENT RESPONSE

THREAT CARD

T-14

MALICIOUS THIRD-PARTY LIBRARY INJECTION

TIER: INJECTION
STEP: INITIAL COMPROMISE
VECTOR: MALWARE

CLUE FOR THREAT ORCHESTRATOR
"Your dependency scanning tool alerts on a typosquatted NPM package (npm package manager) that was installed in your build pipeline. The malicious package has the same name as a popular logging library but with a slight misspell. It has been downloaded 50k times. Your build logs show it was installed 6 days ago."

WHY THIS WORKS
Developers rely on open-source packages from package managers (npm, PyPI, Maven). Attackers upload malicious packages with names similar to popular libraries (typosquatting). Once downloaded, the malicious code runs during build/deployment. This affects every application built from that point forward. DETECTION DIFFICULTY: High Requires dependency scanning and behavior analysis of build processes.

INCIDENT ZERO · INCIDENT RESPONSE

THREAT CARD

T-15

MALICIOUS INSIDER DATA THEFT

STEP: C2 & EXFIL
VECTOR: DATA EXFIL

CLUE FOR THREAT ORCHESTRATOR
"Your DLP system flags a large volume of sensitive data being copied by an IT operations employee during off-hours. Their user account accessed databases they don't normally interact with. The data was copied to a removable USB drive connected to a shared workstation. Security badge logs show they entered the building at 2 AM when the office was empty."

WHY THIS WORKS
Insiders have legitimate access and often bypass security controls. Their activities may not trigger alerts because their permissions are valid. Detection requires: – Behavioral analysis (unusual times/volumes) – Physical security controls – DLP and USB device control – Privileged access management Insiders cause 30-40% of data breaches in many industries. DETECTION DIFFICULTY: Very High Insider actions often look normal to automated systems.

INCIDENT ZERO · INCIDENT RESPONSE

THREAT CARD

T-16

DISGRUNTLED EMPLOYEE SABOTAGE

STEP: PIVOT & ESCALATE
VECTOR: MALWARE

CLUE FOR THREAT ORCHESTRATOR
"A recently terminated database administrator appears to have retained remote access using a dormant service account they created months ago. Logs show connection attempts from their home IP address. They've been modifying stored procedures and adding logic bombs set to trigger in 30 days. Your team notices their employee laptop is still configured with VPN certificates."

WHY THIS WORKS
Disgruntled employees often have privileged access and deep system knowledge. They may have created backdoors before termination. Offboarding failures (not revoking certs, not disabling accounts) are common. Defense requires: – Complete offboarding procedures – Privileged access review – Anomalous activity detection – Behavior analysis for terminated employees DETECTION DIFFICULTY: High Requires correlation of access patterns and employee status changes.

INCIDENT ZERO · INCIDENT RESPONSE

THREAT CARD

T-17

COMPROMISED IOT DEVICE AS PIVOT POINT

TIER: POINT
STEP: INITIAL COMPROMISE
VECTOR: NETWORK

CLUE FOR THREAT ORCHESTRATOR
"Your network monitoring detects unusual traffic from an IoT device (surveillance camera) in the building. The device is communicating with a command server overseas and tunneling internal network traffic. Your asset inventory shows this camera was never formally added to any security program. It's running firmware from 2019 with known vulnerabilities."

WHY THIS WORKS
IoT devices are often neglected in security programs (cameras, printers, thermostats, building automation). They run outdated firmware and have weak or default credentials. Once compromised, they provide network access and can pivot to critical systems. Many organizations don't inventory or monitor IoT devices. DETECTION DIFFICULTY: Medium Requires network monitoring and device inventory practices.

INCIDENT ZERO · INCIDENT RESPONSE

THREAT CARD

T-18

CLOUD API TOKEN THEFT & ABUSE

STEP: PIVOT & ESCALATE
VECTOR: CREDENTIAL ABUSE

CLUE FOR THREAT ORCHESTRATOR
"Your AWS CloudTrail logs show API calls from unusual IP addresses using API keys belonging to a developer who left the company 6 months ago. The calls are creating new IAM users, accessing S3 buckets with customer data, and launching EC2 instances in regions where you don't normally operate. The API key was embedded in old GitHub repository code."

WHY THIS WORKS
Cloud API tokens/keys are often exposed in code repositories or configuration files. Once exposed, they provide direct access to cloud resources. Attackers can spin up resources, steal data, or deploy cryptominers. Many organizations fail to rotate or revoke old API keys. Detection requires: – API audit logging – Anomalous API pattern detection – Key rotation policies – Secrets scanning in repos DETECTION DIFFICULTY: Medium-High Requires cloud monitoring and secrets management practices.

INCIDENT ZERO · INCIDENT RESPONSE

THREAT CARD

T-19

DNS TUNNELING DATA EXFILTRATION

STEP: C2 & EXFIL
VECTOR: DATA EXFIL

CLUE FOR THREAT ORCHESTRATOR
"Your DNS query logs show massive volume of unusual subdomains being queried through an external DNS resolver. The subdomain names look like Base64-encoded data. Queries are happening in steady intervals. Query timestamps align with your database being accessed. Your DLP didn't flag anything because DNS is typically trusted."

WHY THIS WORKS
DNS tunneling encodes data in DNS queries to bypass firewalls and DLP systems. Organizations often allow DNS traffic without inspection. DNS queries are typically high-volume and hard to distinguish from normal activity. Attackers can exfil small amounts of data over weeks. Defense requires: – DNS query content analysis – Anomalous query pattern detection – DNS rate limiting – External DNS access restrictions DETECTION DIFFICULTY: Very High Requires specialized DNS monitoring tools and baseline analysis.

INCIDENT ZERO · INCIDENT RESPONSE

THREAT CARD

T-20

PHYSICAL ACCESS + BADGE CLONING ATTACK

TIER: ATTACK
STEP: INITIAL COMPROMISE
VECTOR: CREDENTIAL ABUSE

CLUE FOR THREAT ORCHESTRATOR
"Your security team discovers that an RFID badge belonging to a manager was cloned using a portable reader. The cloned badge was used to gain access to your secure data center after-hours. Badge access logs are timestamped, but the person's schedule shows they weren't in the office that evening. Your server room CCTV captured footage of an unknown individual installing a wireless device in the network rack."

WHY THIS WORKS
Physical security is often overlooked in cybersecurity programs. RFID badges can be cloned with inexpensive readers. Once inside the data center, attackers can install rogue network devices, steal hardware, or gain console access to servers. Defense requires: – Encrypted badge technology – Multi-factor access (biometric) – CCTV monitoring – Environmental controls – Equipment inventory tracking – Badge deactivation on exit DETECTION DIFFICULTY: High Requires integration of physical and cyber security monitoring.

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-25

APPLICATION WHITELISTING (BASIC)

TIER: BASIC – 10 Budget
COUNTERMEASURE: MALWARE

DESCRIPTION
Deploy application whitelisting on critical workstations and servers. Maintain an approved applications list (Word, Excel, Chrome, etc.). Block execution of any unapproved binaries. Use AppLocker (Windows) or similar tools.

EFFECT
Prevents execution of malware and unauthorized tools. Attackers cannot run ransomware, backdoors, or penetration tools if they're not on the whitelist. Effective against zero-days if not signed by trusted publishers. LIMITATION: False positives if maintenance is poor. Users may struggle with legitimate tools being blocked.

INCIDENT ZERO · INCIDENT RESPONSE



DEFENSE CARD

D-26

ADVANCED APPLICATION CONTROL WITH AI

TIER: ADVANCED - 15 Budget
COUNTERMEASURE: MALWARE

DESCRIPTION

Deploy AI-powered application control that learns normal program execution patterns. System builds a baseline of legitimate applications and automatically flags deviations. Prevents execution of suspicious or anomalous applications.

EFFECT

Combines whitelisting with behavior analysis. Adapts to legitimate new applications without manual updates. Catches polymorphic malware variants that might bypass static whitelisting (different packing, slight name changes). Reduces false positives. LEARNING CURVE: Requires baseline training period (1-2 weeks).

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-27

LIVING-OFF-THE-LAND BLOCKER (ELITE)

TIER: ELITE - 25 Budget
COUNTERMEASURE: MALWARE

DESCRIPTION

Deploy advanced script and tool control that restricts execution of PowerShell, WScript, cmd.exe, and other "living-off-the-land" tools. Allow only specific, monitored usage with strong justification logging. Monitor for obfuscation patterns.

EFFECT

Directly targets attacker techniques used in privilege escalation and lateral movement (scheduled tasks, registry modification, credential dumping). Makes PowerShell and cmd attacks extremely difficult. Works especially well with EDR. IMPACT: May break legitimate admin tasks; requires strong change management.

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-28

BASELINE BEHAVIOR LEARNING SYSTEM (ADVANCED)

TIER: ADVANCED - 15 Budget
COUNTERMEASURE: NETWORK

DESCRIPTION

Deploy behavioral analytics that establishes baseline profiles for users, systems, and network traffic. System learns what "normal" looks like, then alerts on deviations. Monitors: login times, file access, network destinations, resource usage.

EFFECT

Detects anomalies like: - Unusual login geography/time - Data access patterns changing - Lateral movement via SMB - New network destinations Works best as a *combination* with other tools. Requires good baseline data (1-2 weeks of normal traffic). DETECTS: Insider threats, compromised credentials, APT tactics.

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-29

PROCESS BEHAVIOR ANALYSIS (ADVANCED)

TIER: ADVANCED - 15 Budget
COUNTERMEASURE: MALWARE

DESCRIPTION

Deploy process-level behavioral monitoring that learns what each application normally does (file I/O, network calls, registry access, child processes spawned). Blocks anomalous behavior from legitimate binaries.

EFFECT

Catches: - Legitimate apps compromised by supply chain attack - Process injection attacks - Unexpected child process creation - Anomalous registry/file writes Example: Word.exe normally doesn't spawn PowerShell; if it does, block and alert. DETECTS: Zero-day malware, APT techniques, supply chain compromises.

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-30

MACHINE LEARNING ANOMALY DETECTION (ELITE)

TIER: ELITE - 25 Budget
COUNTERMEASURE: MALWARE

DESCRIPTION

Deploy ML models trained on terabytes of security data. System detects subtle anomalies humans would miss: subtle timing changes, rare resource combinations, statistical outliers. Continuously retrains on new data.

EFFECT

Catches advanced attacks that bypass signature and rule-based systems. Detects: - Polymorphic malware variations - Advanced persistent threats (APT) - Zero-day exploits (by behavior) - Sophisticated insider threats - Supply chain compromises TRADE-OFF: False positives require human analysis. Requires large datasets for training.

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-31

CONTAINER IMAGE SCANNING (BASIC)

TIER: BASIC - 10 Budget
COUNTERMEASURE: MALWARE

DESCRIPTION

Scan all container images before deployment for known vulnerabilities and malicious packages. Integrate scanning into CI/CD pipeline. Block images with critical CVEs from being deployed.

EFFECT

Prevents deployment of vulnerable containers. Catches: - Old base images with known CVEs - Malicious packages in dependencies - Secrets accidentally baked into images Works best when combined with runtime monitoring. LIMITATION: Only catches known vulnerabilities (CVE databases).

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-32

CONTAINER RUNTIME PROTECTION (ADVANCED)

TIER: ADVANCED - 15 Budget
COUNTERMEASURE: MALWARE

DESCRIPTION

Deploy runtime security monitoring that enforces security policies on running containers. Monitor syscalls (system calls), network connections, and file access. Enforce AppArmor or SELinux profiles.

EFFECT

Detects and blocks: - Container escape attempts - Lateral movement between containers - Privilege escalation in container - Anomalous process execution - Unexpected network connections Works against both known and unknown attacks (zero-day exploits). REQUIREMENT: Requires kernel-level instrumentation; varies by platform.

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-33

KUBERNETES NETWORK POLICY & RBAC (ELITE)

TIER: ELITE - 25 Budget
COUNTERMEASURE: NETWORK

DESCRIPTION

Implement Kubernetes network policies to restrict container-to-container communication. Deploy role-based access control (RBAC) for API access and service accounts. Enforce pod security policies and admission controllers.

EFFECT

Implements micro-segmentation in containerized environments. Prevents: - Lateral movement between pods - Container escape attacks accessing host network - Privilege escalation via RBAC - Unauthorized Kubernetes API access COMPLEXITY: Requires mature Kubernetes operations and expertise.

INCIDENT ZERO · INCIDENT RESPONSE

DEFENSE CARD

D-34

CLOUD CONFIGURATION AUDITING (BASIC)

TIER: BASIC - 10 Budget
COUNTERMEASURE: CREDENTIAL ABUSE

DESCRIPTION

Deploy continuous cloud configuration monitoring (AWS Config, Azure Policy Manager, GCP Cloud Asset Inventory). Scan for misconfigured resources: - Public S3 buckets - Overly permissive IAM policies - Unencrypted databases - Open security groups

EFFECT

Detects misconfigurations that allow unauthorized access: - Public database access - Exposed credentials in configs - Overly broad IAM permissions - Disabled encryption/logging Alert on drift from secure baseline. LIMITATION: Only catches known misconfiguration patterns.

INCIDENT ZERO · INCIDENT RESPONSE



CLOUD ACCESS & PERMISSION AUDITING (ADVANCED)

TIER: ADVANCED - 15 Budget

COUNTERMEASURE: CREDENTIAL ABUSE

DESCRIPTION

Audit all IAM roles, service accounts, and API credentials for over-privilege. Implement least-privilege access. Regularly review who has what permissions. Detect and revoke unused credentials.

EFFECT

Prevents attackers from leveraging: - Exposed API keys with broad permissions - Service accounts with admin access - Stale credentials from departed employees - Cross-account trust abuse Reduces blast radius if credentials are compromised. **REQUIRES:** Strong governance process to maintain least-privilege state.

INCIDENT ZERO · INCIDENT RESPONSE

CLOUD COMPLIANCE & AUDIT TRAIL (ELITE)

TIER: ELITE - 25 Budget

COUNTERMEASURE: DATA EXFIL

DESCRIPTION

Enable comprehensive cloud audit logging (CloudTrail, Stackdriver, Activity Monitor). Forward all logs to immutable, centralized storage. Monitor for unauthorized API calls, data access, and resource changes. Enable MFA Delete on audit logs.

EFFECT

Provides forensic trail for: - Detecting API token abuse - Investigating data exfiltration - Compliance reporting - Incident response timeline Prevents attackers from covering tracks (immutable logs). Enables rapid investigation of cloud API compromises. **COST:** High storage requirements.

INCIDENT ZERO · INCIDENT RESPONSE

PLAYBOOK: RANSOMWARE RESPONSE (ADVANCED)

TIER: ADVANCED - 15 Budget

COUNTERMEASURE: MALWARE

DESCRIPTION

Pre-built, tested ransomware response playbook covering: - Immediate network isolation steps - Communication procedures - Forensic data collection - Restoration procedures - Stakeholder notifications Train incident response team on playbook annually.

EFFECT

During Phase 2 or when ransomware is detected: Get +4 bonus to defense rolls when responding to ransomware threats. Reduces response time, limiting damage. **EDUCATIONAL VALUE:** Teaches incident response process and coordination.

INCIDENT ZERO · INCIDENT RESPONSE

PLAYBOOK: CREDENTIAL COMPROMISE RESPONSE (ADVANCED)

TIER: RESPONSE (ADVANCED - 15 Budget

COUNTERMEASURE: CREDENTIAL ABUSE

DESCRIPTION

Pre-built playbook for credential compromise scenarios: - Identify affected accounts - Forced password reset procedures - Session invalidation - MFA re-enrollment process - Forensic user activity review - Privileged account audit

EFFECT

When investigating compromised credentials: Get +4 bonus to defense rolls. Allows rapid containment before lateral movement occurs. **EXAMPLE USE:** During "Mimikatz Credential Dumping" threat, playbook helps isolate affected accounts.

INCIDENT ZERO · INCIDENT RESPONSE

PLAYBOOK: INSIDER THREAT RESPONSE (ELITE)

TIER: ELITE - 25 Budget

COUNTERMEASURE: DATA EXFIL

DESCRIPTION

Comprehensive insider threat response playbook including: - HR coordination protocols - Legal review and preservation - Forensic evidence collection - Physical security response - System access removal procedures - Communication to management Requires cross-functional team coordination.

EFFECT

When responding to insider threats: Get +5 bonus to defense rolls. Requires strong organizational processes to be effective. **EXAMPLE USE:** When "Malicious Insider Data Theft" is detected, playbook coordinates response across security, HR, legal, and executives.

INCIDENT ZERO · INCIDENT RESPONSE

PLAYBOOK: SUPPLY CHAIN BREACH RESPONSE (ELITE)

TIER: RESPONSE (ELITE - 25 Budget

COUNTERMEASURE: WEB EXPLOIT

DESCRIPTION

Specialized playbook for supply chain compromises: - Vendor notification procedures - Industry coordination - Affected system inventory - Patch deployment prioritization - Third-party impact assessment - Public communication strategy

EFFECT

During Phase 2 when defending against supply chain attacks: Get +5 bonus to defense rolls. Requires vendor relationships and industry collaboration. **LEARNING:** Teaches that supply chain incidents require industry response.

INCIDENT ZERO · INCIDENT RESPONSE

BACKUP STRATEGY - 3-2-1 RULE (BASIC)

TIER: BASIC - 10 Budget

COUNTERMEASURE: MALWARE

DESCRIPTION

Implement the 3-2-1 backup rule: - 3 copies of data - 2 different media types - 1 copy offline/offsite Regular backup verification testing. Document retention and recovery RPO/ RTO (Recovery Point/Time Objectives).

EFFECT

If ransomware encrypts data: Recovery becomes possible without paying ransom. Offline backups ensure attacker cannot delete them. Reduces ransomware attack impact significantly. **LIMITATION:** Only effective if backups are regularly tested and truly offline.

INCIDENT ZERO · INCIDENT RESPONSE

IMMUTABLE BACKUP STORAGE (ADVANCED)

TIER: ADVANCED - 15 Budget

COUNTERMEASURE: MALWARE

DESCRIPTION

Deploy backup storage with WORM (Write-Once-Read-Many) protection. Once backups are written, they cannot be modified or deleted, even by administrators. Implement MFA Delete on storage. Use air-gapped backup network.

EFFECT

Even if attacker gains admin access or compromises backup system: Backups remain protected and unmodifiable. Enables guaranteed recovery. Works against double-extortion ransomware attacks. **COST:** Higher storage cost for immutable solutions.

INCIDENT ZERO · INCIDENT RESPONSE

DISASTER RECOVERY PLAN & TESTING (ELITE)

TIER: ELITE - 25 Budget

COUNTERMEASURE: MALWARE

DESCRIPTION

Establish comprehensive disaster recovery plan (DRP) including: - Failover procedures - Alternate site readiness - Recovery procedures (step-by-step) - Communication protocols - Key personnel contacts Conduct quarterly DRP drills and recovery testing.

EFFECT

During ransomware or supply chain attacks: Get +3 bonus to all defense rolls after initial containment. Enables business continuity. **EDUCATIONAL VALUE:** Teaches business continuity planning and resilience.

INCIDENT ZERO · INCIDENT RESPONSE

